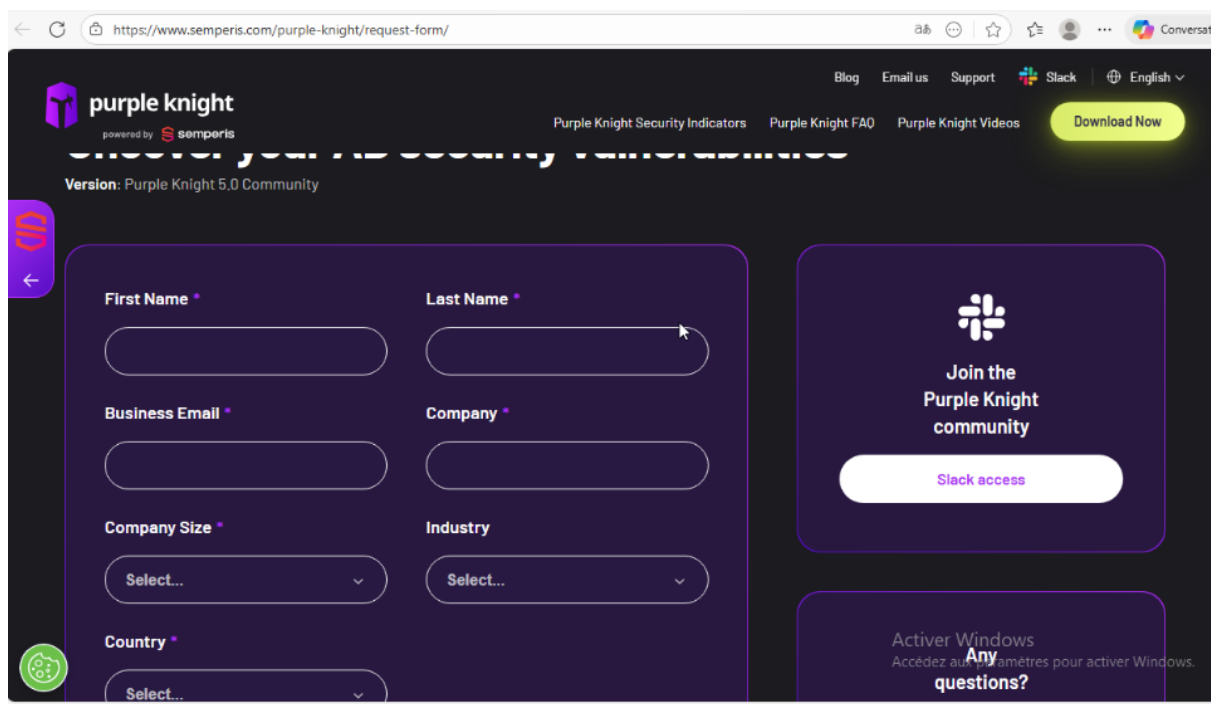


Audit de Sécurité Active Directory avec Purple Knight

1. Introduction à l'outil

Purple Knight est un outil d'audit de sécurité développé par Semperis. Contrairement à un simple scanner de vulnérabilités, il se concentre sur les **Indicateurs d'Exposition (IoE)** et les **Indicateurs de Compromission (IoC)** spécifiques à l'Active Directory.

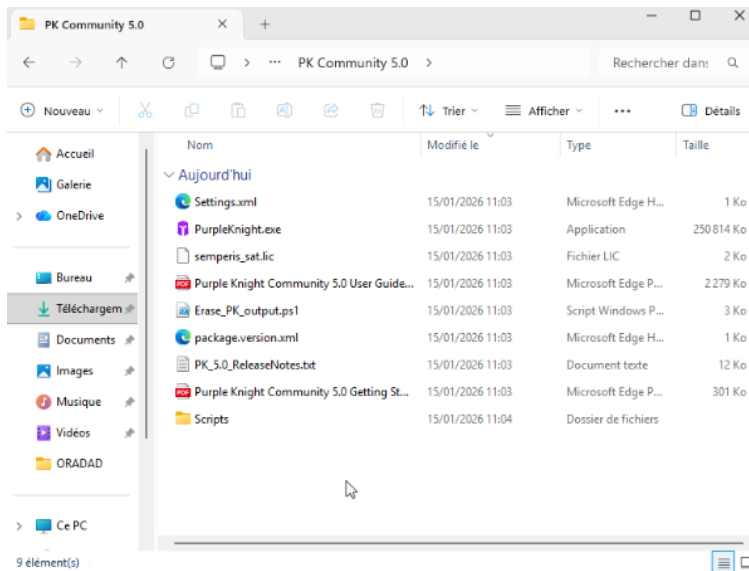


The screenshot shows the 'request-form' page for Purple Knight on the Semperis website. The page has a dark theme with purple accents. At the top, there's a navigation bar with links for 'Blog', 'Email us', 'Support', 'Slack', and 'English'. A 'Download Now' button is also present. The main content area features a form for requesting the tool, with fields for 'First Name', 'Last Name', 'Business Email', 'Company', 'Company Size', 'Industry', and 'Country'. To the right of the form, there's a section titled 'Join the Purple Knight community' with a 'Slack access' button. At the bottom right, there's a small section titled 'Active Windows' with a link to 'Any questions?'. The URL in the browser's address bar is 'https://www.semperis.com/purple-knight/request-form/'.

2. Phase de Lancement et Configuration

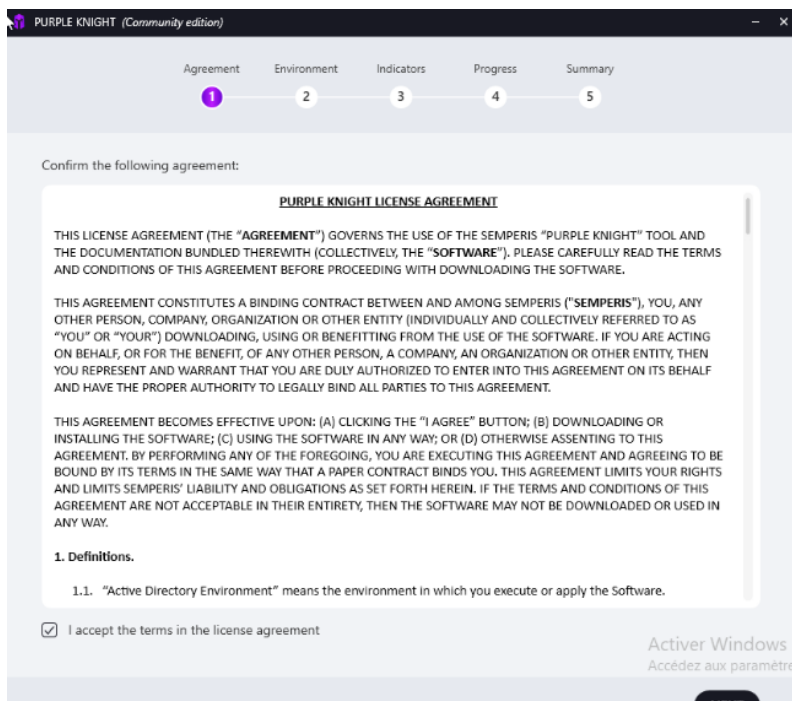
A. Exécution du programme

- **Action** : Lancement de PurpleKnight.exe.
- **Commentaire** : L'outil s'exécute sans installation. Il nécessite d'être lancé depuis une machine membre du domaine avec un compte disposant de droits de lecture sur l'ensemble de l'annuaire (généralement un administrateur du domaine pour un scan complet).



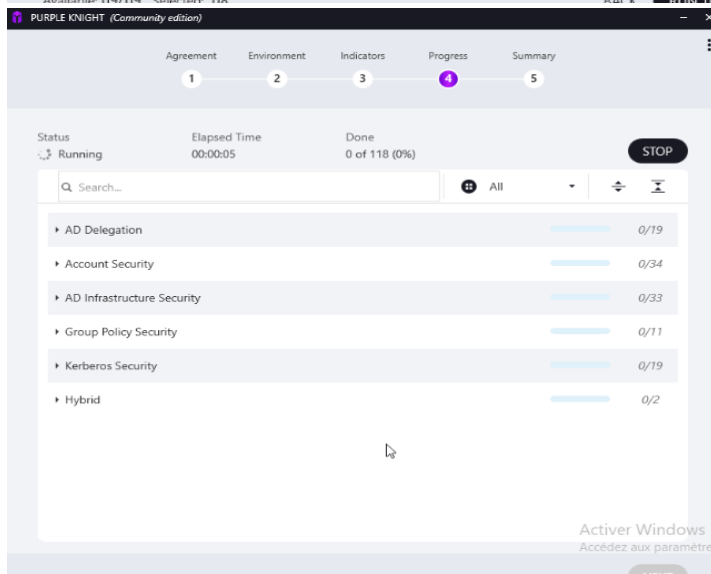
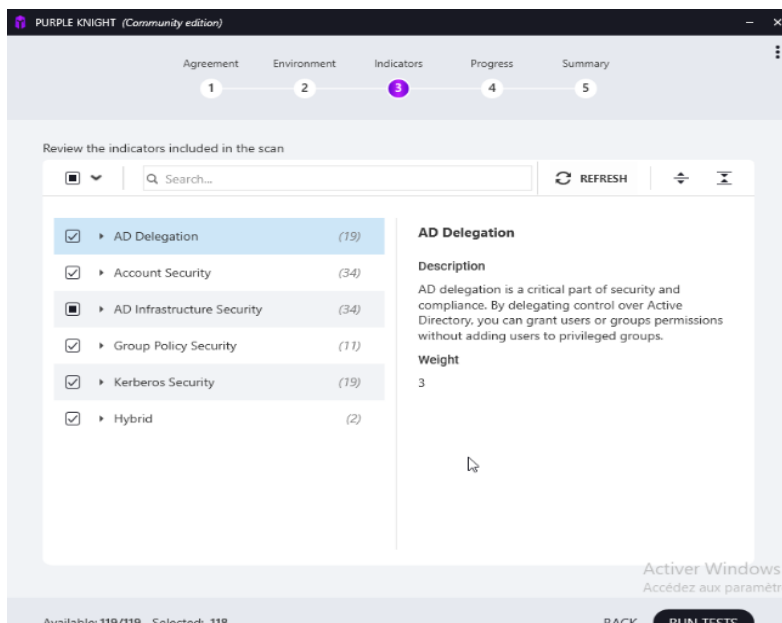
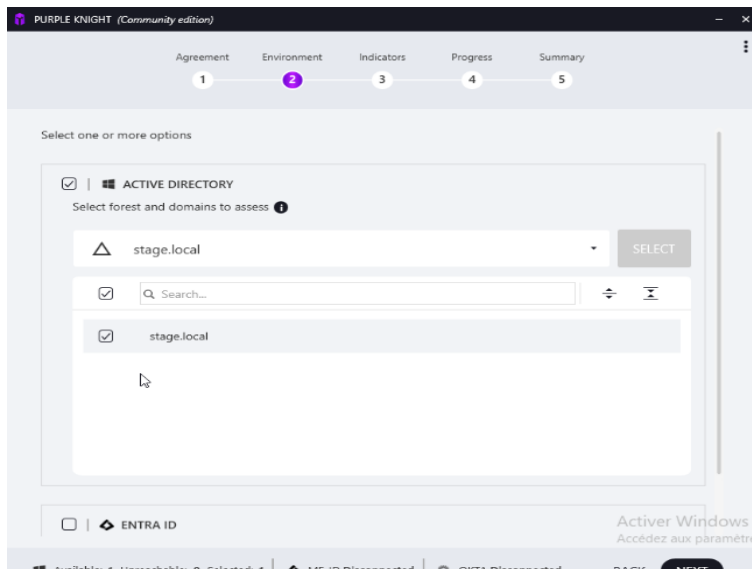
B. Acceptation des termes et conditions

- **Action** : Validation de la licence "Community Edition".
- **Commentaire** : Cette version est gratuite pour les audits ponctuels et permet d'accéder à plus de 100 indicateurs de sécurité mis à jour régulièrement.



C. Sélection du périmètre

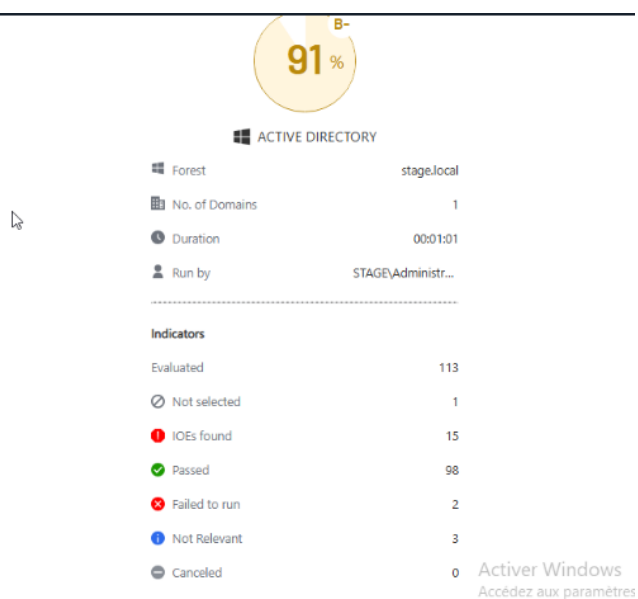
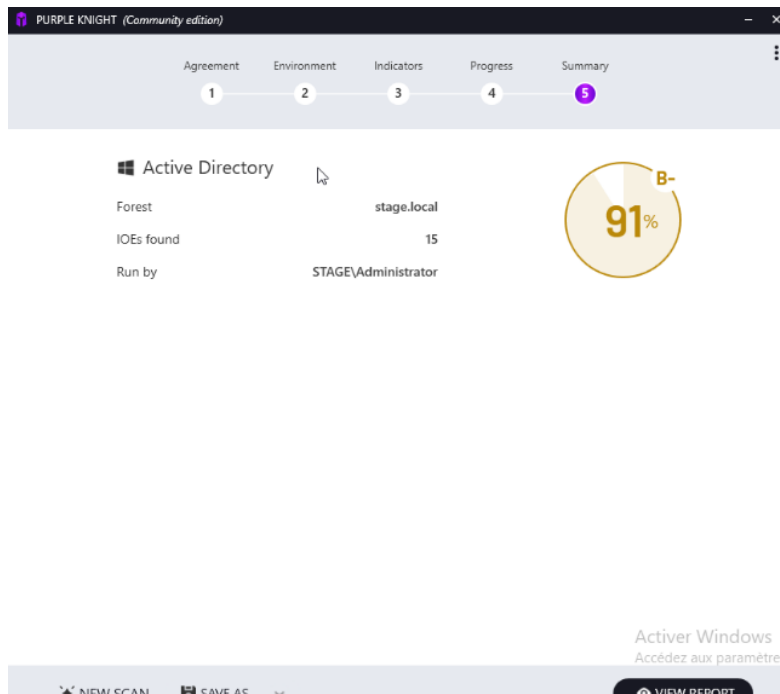
- **Action** : Choix du domaine stage.local.
- **Commentaire** : L'outil détecte automatiquement la forêt et le domaine actuels. On sélectionne ici l'Active Directory comme cible principale.



3. Analyse du Score Global

Référence : Image 11.

- **Score obtenu : 91% (Grade B-).**
- **Explication :** Ce score est une moyenne pondérée. Bien que le chiffre semble élevé, la présence de vulnérabilités dans la catégorie "Critical" (Sévérité Critique) signifie que le domaine peut être compromis malgré une bonne note globale.



ACTIVE DIRECTORY RESULTS

Categories



AD DELEGATION

AD delegation is a critical part of security and compliance. By delegating control over Active Directory, you can grant users or

[Read More](#)



ACCOUNT SECURITY

Account Security indicators pertain to security weaknesses on individual accounts - built-in or otherwise, within Active

[Read More](#)



AD INFRASTRUCTURE SECURITY

AD Infrastructure Security indicators pertain to the security configuration of core parts of AD's own infrastructure configuration.

[Read More](#)



GROUP POLICY SECURITY

Group Policy Security indicators pertain to the security configuration of GPOs and their deployment within AD.

[Read More](#)



KERBEROS SECURITY

Kerberos Security indicators pertain to the configuration of Kerberos capabilities on computer and user accounts within AD.

[Read More](#)



HYBRID

Hybrid indicators help you understand and mitigate the risks associated with a hybrid identity environment. Active Directory is a

[Read More](#)

CRITICAL IOEs FOUND

SMB Signing is not required on Domain Controllers

This indicator looks for domain controllers where SMB signing is not required.

[Read More](#)

SMBv1 is enabled on Domain Controllers

This indicator looks for domain controllers where SMBv1 protocol is enabled.

[Read More](#)

ADDITIONAL IOEs FOUND

NAME	PLATFORM	SEVERITY LEVEL	ACTION
• LDAP signing is not required on Domain Controllers	Windows AD	High	Read More
• Write access to RBCD on DC	Windows AD	High	Read More
• Write access to RBCD on krbtgt account	Windows AD	High	Read More
• Built-in domain Administrator account used within the last two weeks	Windows AD	Medium	Read More
• gMSA not in use	Windows AD	Medium	Read More
• Primary users with SPN not supporting AES encryption on Kerberos	Windows AD	Medium	Read More
• Domains with obsolete functional levels	Windows AD	Low	Read More
• Recent privileged account creation activity	Windows AD	Low	Read More
• Unprivileged users can add computer accounts to the domain	Windows AD	Low	Read More
• Users with SPN defined	Windows AD	Low	Read More
• AD objects created within the last 10 days	Windows AD	Info	Read More
• Protected Users group not in use	Windows AD	Info	Read More
• Users with Password Never Expires flag set	Windows AD	Info	Read More

Sévérité Élevée (High)

- **LDAP signing is not required on Domain Controllers** : l'absence de signature LDAP obligatoire permet à un attaquant de réaliser des attaques de type "Man-in-the-Middle" pour intercepter ou modifier des requêtes d'annuaire.
- **Write access to RBCD on DC / krbtgt account** : ces indicateurs signalent des permissions dangereuses sur la délégation Kerberos (Resource-Based Constrained Delegation), pouvant mener à une compromission totale du contrôleur de domaine.

Sévérité Moyenne (Medium)

- **Built-in domain Administrator account used within the last two weeks** : l'utilisation fréquente du compte "Administrator" par défaut est une mauvaise pratique ; il est recommandé d'utiliser des comptes nominatifs pour l'administration quotidienne.
- **gMSA not in use** : le système n'utilise pas de comptes de service gérés par le groupe (Group Managed Service Accounts), qui gèrent automatiquement la rotation des mots de passe.
- **Primary users with SPN not supporting AES encryption on Kerberos** : certains comptes utilisent des chiffrements Kerberos obsolètes et plus vulnérables.

Sévérité Faible ou Information (Low / Info)

- **Unprivileged users can add computer accounts to the domain** : ce point confirme l'alerte de **PingCastle** : par défaut, tout utilisateur peut joindre jusqu'à 10 machines au domaine.
- **AD objects created within the last 10 days** : un rappel des créations récentes d'objets (utilisateurs, groupes) dans votre environnement.
- **Protected Users group not in use** : vous n'utilisez pas encore ce groupe de sécurité spécial qui applique des restrictions renforcées sur les comptes sensibles.
- **Users with Password Never Expires flag set** : signale les comptes dont les mots de passe n'expirent jamais, ce qui est une cible privilégiée pour les attaques par force brute.

4. Analyse des Vulnérabilités Critiques (Les "Critiques")

gMSA not in use

Cet indicateur vérifie s'il existe des objets de type "Group Managed Service Account" actifs dans le domaine.

- **Explication (Cause)** : L'infrastructure actuelle utilise des comptes utilisateurs classiques ou des comptes de service locaux pour faire fonctionner les applications

et services réseau. Ces comptes standards nécessitent une gestion manuelle des mots de passe.

- **Conséquence (Risque)** : L'absence de **gMSA** rend les comptes de service plus vulnérables aux compromissions. Contrairement aux comptes classiques, la fonctionnalité **gMSA** permet une rotation automatique et complexe des mots de passe gérée par l'Active Directory, ce qui les rend extrêmement difficiles à craquer par force brute ou à voler via des attaques sur les systèmes où ils sont utilisés.



SECURITY INDICATOR
gMSA not in use

IOE Found 

SEVERITY

Medium

WEIGHT

4

Security Frameworks

MITRE ATT&CK

- Credential Access

Description

This indicator checks if there are enabled group Managed Service Account (gMSA) objects in the domain.

Likelihood of Compromise

The group Managed Service Account (gMSA) feature in Windows Server 2016 allows automatic rotation of passwords for service accounts, making them much more difficult for attackers to compromise. The feature should be used whenever possible for service accounts.

References

[Get started with Group Managed Service Accounts](#)

Result

Found 1 domains with no gMSA objects enabled.

DomainName	Ignored
stage.local	False

Showing 1 of 1

Remediation Steps

Group Managed Service Accounts should be used to protect service accounts. See description for more information.

Activer Windows
Accédez aux paramètres pour activer Windows

Unprivileged users can add computer accounts to the domain

Cet indicateur vérifie la configuration de l'Active Directory qui autorise les membres ordinaires du domaine à joindre des machines à l'annuaire.

- **Explication (Cause)** : Par défaut, l'attribut ms-DS-MachineAccountQuota sur la tête de l'annuaire est réglé sur **10**. Cela signifie que n'importe quel membre du groupe "Utilisateurs authentifiés" a le droit de créer jusqu'à 10 comptes d'ordinateurs dans le domaine sans l'intervention d'un administrateur.
- **Conséquence (Risque)** : Cette capacité offre des opportunités aux attaquants pour introduire leurs propres machines sur le réseau ou pour exploiter des vulnérabilités sur des ordinateurs non contrôlés. Cela peut faciliter les **mouvements latéraux** à l'intérieur de l'infrastructure stage.local et permettre des attaques basées sur le protocole Kerberos.

Unprivileged users can add computer accounts to the domain

IOE Found

96%

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Credential Access
- Lateral Movement

ANSSI

- vuln4_user_accounts_machineaccountquota

Description

This indicator checks for an AD configuration that allows unprivileged domain members to add computer accounts to the domain. By default, members of the Authenticated Users group can add up to 10 machine accounts to a domain. If the ms-DS-MachineAccountQuota attribute on the domain naming context head is not set to 0, regular users have this ability. The ability to do this confers certain rights on those created machine accounts that can be abused by a variety of Kerberos-based attacks. Note: This configuration may be enabled but be already mitigated by GPO settings (User Right: "Add workstations to domain" configured with only high-privileged group(s)/account(s)) linked to Domain Controllers OU that are not checked by this indicator.

Likelihood of Compromise

The ability to add computer accounts to a domain without restrictions or monitoring present opportunities for attackers to add their own accounts or take advantage of uncontrolled computers with vulnerabilities, thereby extending their reach and entrenching themselves in the environment.

References

[Unrestricted domain join | ANSSI](#)

Result

Found 1 domains in which regular users can add computer accounts.

MachineAccountQuota	DistinguishedName	Ignored
10	DC=stage,DC=local	False

Showing 1 of 1

Remediation Steps

Set the ms-DS-MachineAccountQuota attribute on the domain NC head to 0 to disable regular users' ability to add computer accounts.

Active Windows

Accédez aux paramètres pour activer Win

Built-in domain Administrator account used within the last two weeks

Cet indicateur vérifie si la valeur de l'attribut lastLogonTimestamp du compte administrateur par défaut a été mise à jour au cours des deux dernières semaines.

- Explication (Cause) :** Le compte "**Administrator**" (intégré par défaut lors de la création de l'Active Directory) a été utilisé pour effectuer des tâches d'administration, de configuration ou de maintenance sur le domaine stage.local au cours des 14 derniers jours.
- Conséquence (Risque) :** L'utilisation de ce compte générique est une **mauvaise pratique de sécurité** car elle empêche la traçabilité nominative des actions d'administration. Si ce compte est compromis, l'attaquant dispose immédiatement des privilèges les plus élevés sur toute la forêt. De plus, comme il s'agit d'un compte hautement privilégié, une brèche sur celui-ci est difficile à détecter et peut avoir des conséquences désastreuses sur l'intégrité de l'infrastructure.

1

SECURITY INDICATOR

Built-in domain Administrator account used within the last two weeks

IOE Found

91

SEVERITY

Medium

WEIGHT

5

Security Frameworks

MITRE ATT&CK

- Credential Access

MITRE D3FEND

- Detect - Credential Compromise Scope Analysis
- Harden - Strong Password Policy

Description

The Domain Administrator account should only be used for initial build activities and, when necessary, disaster recovery. This indicator checks to see if the lastLogonTimestamp for the built-in Domain Administrator account has been updated within the last two weeks. If so, it could indicate that the user has been compromised.

Likelihood of Compromise

If best practices are followed and domain Admin is not used, this would indicate a compromise. Ensure any logins to the built-in Domain Administrator account are legitimate and accounted for. If not accounted for, a breach is likely and should be investigated.

Result

Found 1 domains in which the built-in administrator was used recently.

DistinguishedName	EventTimestamp	Ignored
CN=Administrator,CN=Users,DC=stage,DC=local	14/01/2026 14:06:23	False

Showing 1 of 1

Remediation Steps

Ensure that the built-in domain Administrator account is not used regularly and has a complex password known only to highly privileged admins.

Activer Windows

Accédez aux paramètres pour activer W

AD objects created within the last 10 days

Cet indicateur est utilisé pour la surveillance proactive (**threat hunting**) et la validation de la conformité des changements récents dans l'Active Directory.

- **Explication (Cause)** : L'outil a scanné la base de données de l'annuaire stage.local pour lister tous les nouveaux objets (utilisateurs, conteneurs, politiques) dont la date de création est récente.
- **Conséquence (Risque)** : Bien que cet indicateur ne soit pas une vulnérabilité en soi, il est crucial pour détecter des **comptes "dormants" ou illégitimes** créés par un attaquant après une intrusion pour maintenir un accès persistant. Une augmentation soudaine et inexpliquée d'objets peut être le signe d'une compromission en cours.

SEVERITY

Info

WEIGHT

1

Security Frameworks

MITRE ATT&CK

- Lateral Movement
- Persistence

MITRE DEFEND

- Detect - Domain Account Monitoring

Description

This indicator looks for any AD objects that were created within the last 10 days. It is meant to be used for threat hunting, post breach investigation or compliance validation.

Likelihood of Compromise

In some environments, object creation happens consistently; however, recently added accounts should be reviewed to ensure they are legitimate.

References

[Audit User Account Management | Microsoft Learn](#)

Result

Found 244 objects that were created in the last 10 days.

DistinguishedName	ObjectName	ObjectClass	EventTimestamp
CN=ipsecNFA(7238523E-70FA-11D1-864C-14A300000000),CN=IP Security,CN=System,DC=stage,DC=local	ipsecNFA(7238523E-70FA-11D1-864C-14A300000000)	ipsecNFA	14/01/2026 13:49:55
CN=e599e791-d96d-47c9-93c9-d55e1dc439ba,CN=Operations,CN=DomainUpdates,CN=System,DC=stage,DC=local	e599e791-d96d-47c9-93c9-d55e1dc439ba	container	14/01/2026 13:49:58
CN=e6d59d30-385d-4e65-b02d-9da3493ed850,CN=Operations,CN=DomainUpdates,CN=System,DC=stage,DC=local	e6d59d30-385d-4e65-b02d-9da3493ed850	container	14/01/2026 13:49:58
CN=5c82b233-75fc-41b3-ac71-c69592e68f15,CN=Operations,CN=DomainUpdates,CN=System,DC=stage,DC=local	5c82b233-75fc-41b3-ac71-c69592e68f15	container	14/01/2026 13:49:54
CN=Machine,CN=JAC1786C-016F-11D2-945F-00C04F8984F9,CN=Policies,CN=System,DC=stage,DC=local	Machine	container	14/01/2026 13:49:55
CN=FileLinks,CN=System,DC=stage,DC=local	FileLinks	FileLinkTracking	14/01/2026 13:49:55
CN=ipsec(SAKMPPolicy)(72385237-70FA-11D1-864C-14A300000000),CN=IP Security,CN=System,DC=stage,DC=local	ipsec(SAKMPPolicy)(72385237-70FA-11D1-864C-14A300000000)	ipsec(SAKMPPolicy)	14/01/2026 13:49:55
CN=16079587-80cf-45a2-890b-6c997ed6a284,CN=Operations,CN=DomainUpdates,CN=System,DC=stage,DC=local	16079587-80cf-45a2-890b-6c997ed6a284	container	14/01/2026 13:49:54
CN=ipsecNFA(59119C34-5EE3-11D2-ACE8-0060B0ECCA17),CN=IP Security,CN=System,DC=stage,DC=local	ipsecNFA(59119C34-5EE3-11D2-ACE8-0060B0ECCA17)	ipsecNFA	14/01/2026 13:49:55
CN=Administrator,CN=Users,DC=stage,DC=local	Administrator	user	14/01/2026 13:49:55

Showing 10 of 244
[View additional results](#)

Remediation Steps

Ensure that the new objects are known and legitimate.

Activer Windows
Accédez aux paramètres pour activ

Recent privileged account creation activity

Cet indicateur recherche les utilisateurs ou groupes créés au cours du dernier mois dont l'attribut adminCount est défini sur **1**.

- **Explication (Cause)** : L'outil a détecté la création ou l'activation de nouveaux comptes disposant de droits d'administration élevés sur le domaine stage.local au cours des 30 derniers jours. Dans le cadre de du projet, cela correspond à la phase d'installation et de configuration initiale de du serveur UCS.
- **Conséquence (Risque)** : Dans un environnement de production stable, la création de comptes privilégiés doit être un processus rare, étroitement contrôlé et audité. Un attaquant ayant réussi à pénétrer le réseau cherchera souvent à créer son propre compte "Super Admin" pour garantir son maintien dans le système. Cet indicateur permet donc de repérer immédiatement toute élévation de privilèges suspecte qui n'aurait pas été officiellement validée.

Recent privileged account creation activity

IOE Found

92%

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Persistence

MITRE D3FEND

- Detect - Domain Account Monitoring

Description

This indicator looks for any users or groups that were created within the last month. Privileged accounts and groups are defined by having their adminCount attribute set to 1.

Likelihood of Compromise

In most environments, creation of privileged accounts and groups is tightly controlled and audited. This indicator provides a fast method to create a list of new privileged accounts (where adminCount = 1) for investigation and review.

References

[audit-user-account-management of Microsoft](#)

Result

Found 2 objects that were created in the last 30 days and are members of a privileged group.

DistinguishedName	SamAccountName	EventTimestamp	Ignored
CN=Administrator,CN=Users,DC=stage,DC=local	Administrator	14/01/2026 13:49:55	False
CN=krbtgt,CN=Users,DC=stage,DC=local	krbtgt	14/01/2026 13:49:55	False

Showing 2 of 2

Remediation Steps

Review the list and verify that all privileged accounts and groups that were recently created are valid. Ideally, all privileged account creation goes through an approval-based workflow and gets periodic attestation.

Activer Windows

Accédez aux paramètres pour activer Wi

Protected Users group not in use

Le groupe "**Protected Users**" est un groupe de sécurité spécial introduit par Microsoft (depuis Windows Server 2012 R2) pour protéger les comptes à hauts privilèges.

- **Explication (Cause)** : L'audit indique qu'aucun compte utilisateur n'a été ajouté à ce groupe spécifique dans votre domaine stage.local. Par défaut, lors de la création d'un domaine (même sur UCS), ce groupe est vide.
- **Conséquence (Risque)** : Sans l'utilisation de ce groupe, les comptes administrateurs bénéficient de protections standards. En n'y ajoutant pas les comptes sensibles, je suis privé de restrictions de sécurité automatiques et puissantes, notamment :
 1. L'impossibilité d'utiliser des protocoles d'authentification faibles (comme NTLM ou WDigest).
 2. L'interdiction de mettre en cache les identifiants (credentials) sur les postes de travail.
 3. Une durée de vie des tickets Kerberos beaucoup plus courte (4h au lieu de 10h).

SECURITY INDICATOR

Protected Users group not in use

IOE Found

99%

SEVERITY

Info

WEIGHT

1

Security Frameworks

MITRE ATT&CK

- Credential Access

ANSSI

- vuln3_protected_users

Description

This indicator checks if privileged users are in the Protected Users security group.

Likelihood of Compromise

The Protected Users security group was introduced in Server 2012 R2 Active Directory to minimize credential exposure for privileged accounts. As a defense in depth measure privileged accounts, such as Domain Admins, should be added to the Protected Users security group. Attackers targeting privileged accounts in Active Directory will find a much higher level of friction in certain types of attempts to compromise the accounts due to the protections offered.

References

[Protected Users Security Group | Microsoft Learn](#)
[Privileged accounts outside of the Protected Users group | ANSSI](#)

Result

Found 1 privileged users that are not members of the Protected Users group.

DistinguishedName	SamAccountName	Enabled	Ignored
CN=Administrator,CN=Users,DC=stage,DC=local	Administrator	True	False

Showing 1 of 1

Remediation Steps

Ensure that all privileged users are members of the Protected Users group. If using a pre 2012-R2 schema, then the protected users group does not exist. This is an exposure, but the remediation is to upgrade the schema.

Active Windows

Accédez aux paramètres pour activer Windows

Users with Password Never Expires flag set

Cet indicateur identifie les comptes utilisateurs où l'option "Le mot de passe n'expire jamais" est activée.

- Explication (Cause)** : Certains comptes, souvent des comptes de service ou des comptes utilisés pour des applications spécifiques, sont configurés pour que leur mot de passe ne soit jamais renouvelé afin d'éviter des interruptions de service. Dans mon cas, il s'agit du compte dns-serv-ucs.
- Conséquence (Risque)** : Ces comptes sont des cibles privilégiées pour les attaques par **force brute**. Si un mot de passe n'est jamais changé, un attaquant a tout le temps nécessaire pour tenter de le deviner. Une fois compromis, l'identifiant offre un accès permanent à l'infrastructure, facilitant les **mouvements latéraux** ou l'escalade de privilèges sans que la sécurité ne soit jamais réinitialisée par un changement de mot de passe obligatoire.

Accédez aux paramètres pour activer Wir

- **Explication (Cause)** : le domaine stage.local est actuellement configuré avec un niveau fonctionnel **2008 R2**. Dans un environnement Univention (UCS), Samba 4 émule souvent ce niveau par défaut pour assurer la compatibilité avec un large éventail de clients et de serveurs.
- **Conséquence (Risque)** : L'utilisation d'un niveau fonctionnel ancien n'est pas une faille de sécurité directe, mais elle constitue une **faiblesse structurelle**. Cela empêche l'activation et l'utilisation des fonctionnalités de sécurité modernes de l'Active Directory, telles que :
 1. La **Corbeille Active Directory** (pour une récupération facile des objets supprimés).
 2. Les protections avancées du groupe **"Protected Users"**.
 3. Les politiques de silos d'authentification qui limitent la portée des tickets Kerberos.

1

SECURITY INDICATOR

Domains with obsolete functional levels

ICE Found 96

SEVERITY

Low

WEIGHT

8

Security Frameworks

MITRE ATTACK

- Reconnaissance

MITRE DEFEND

- Harden - Software Update

ANSSI

- vuln1_functional_level
- vuln3_functional_level
- vuln4_functional_level

Description

This indicator looks for AD domains that have a domain functional level set to Windows Server 2012 R2 or lower. These lower functional levels mean that newer security features available in AD cannot be leveraged. If the OS version of your domain controllers supports it, you should update to a newer domain functional level to take full advantage of security advancements in AD.

Likelihood of Compromise

While domain functional level is not a weakness in and of itself, an attacker with knowledge of functional levels can adjust their approach to take advantage of lack of security features in AD.

References

[Forest and Domain Functional Levels](#)
[Raise forest and domain functional levels \(ANSSI\)](#)

Result

Found 1 domains with low domain functionality level.

FunctionalLevelInfo	FunctionalLevel	DomainName	Ignored
2008 R2	4	stage.local	False

Showing 1 of 1

Remediation Steps

Ensure that your AD domains are running at the highest functional level available for your OS version to ensure access to the latest security improvements. Also, consider upgrading the OS to 2016 or above, as new functional levels are available.

Activer Windows

Accédez aux paramètres pour activer Windows

LDAP signing is not required on Domain Controllers

Cet indicateur vérifie si les contrôleurs de domaine exigent que les clients négocient la signature LDAP.

- **Explication (Cause)** : Par défaut, pour maintenir la compatibilité avec des applications ou des clients plus anciens, le serveur n'oblige pas la signature des communications LDAP. Cela signifie que le trafic réseau LDAP circule sans protection d'intégrité garantie.
- **Conséquence (Risque)** : Le trafic réseau non signé est exposé à des attaques de type **Man-in-the-Middle (MitM)**. Un attaquant peut intercepter les paquets, les modifier et les renvoyer au serveur LDAP. Cela peut amener le serveur à prendre des décisions basées sur des requêtes falsifiées provenant d'un client LDAP, ce qui peut conduire à une élévation de privilèges ou au vol d'informations sensibles.

1

SECURITY INDICATOR

LDAP signing is not required on Domain Controllers

ICE Found 82

SEVERITY

High

WEIGHT

7

Security Frameworks

MITRE ATTACK

- Privilege Escalation
- Credential Access

Description

This indicator checks for domain controllers where LDAP signing is not required.

Likelihood of Compromise

Unsigned network traffic is exposed to MITM attacks, where attackers alter packets and forward them to the LDAP server, causing the server to make decisions based on forged requests from the LDAP client.

References

[Domain controller LDAP server signing requirements - Windows 10 | Microsoft Learn](#)
[Network security LDAP client signing requirements - Windows 10 | Microsoft Learn](#)

Result

Found 1 DCs that do not require LDAP Signing.

DistinguishedName	HostName	State	Ignored
CN=SERVER,UCLD=Domain Controllers,DC=stage,DC=local	serv-uclstage.local	Ldap Signing Not Required	False

Showing 1 of 1

Remediation Steps

To remediate, follow the steps below:
If the steps are not followed in order, disruption to Active Directory may occur.

1. Configure clients to request LDAP signing. Group policy: [Network security LDAP client signing requirements](#), select [Negotiate signing](#).
2. When all clients request signing, configure domain controllers to require LDAP signing. Group policy: [Domain Controller LDAP server signing requirements](#), select [Require signing](#).
3. Configure clients to require LDAP signing. Group policy: [Network security LDAP client signing requirements](#), select [Require signing](#).
4. For full details on the process please see the reference articles.

SMB Signing is not required (La signature)

- **La Cause** : Même si j'utilises une version plus récente (SMBv2 ou v3), le serveur n'oblige pas les clients à "signer" numériquement leurs messages.
- **La Conséquence** : C'est une faille de type "usurpation" (Man-in-the-Middle). Un pirate se place entre l'administrateur et le serveur. Comme le serveur ne vérifie pas la signature des messages, le pirate peut intercepter la connexion de l'admin et se faire passer pour lui pour envoyer des ordres au serveur.

SECURITY INDICATOR
SMB Signing is not required on Domain Controllers

ICE Found **73**

SEVERITY

Critical

WEIGHT

8

Security Frameworks
MITRE ATTACK

- Privilege Escalation
- Credential Access

Description
This indicator looks for domain controllers where SMB signing is not required.

Likelihood of Compromise
Unsigned network traffic is susceptible to attacks abusing the NTLM challenge response protocol. A common example of such attacks is SMB Relay, where an attacker is positioned between the client and the server in order to capture data packets transmitted between the two, thus gaining unauthorized access to the server or other servers on the network.

References
[Configure SMB Signing with Confidence](#)

Result
Found 1 DCs that do not require SMB Signing.

DistinguishedName	HostName	State	Ignored
CN=SERV_UCL,OU=Domain Controllers,DC=stage,DC=local	serv-ucstage.local	SMB Signing is not required	False

Showing 1 of 1

Remediation Steps
The following Group Policies need to be enabled in order to enforce SMB Signing on DCs:
1. Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Microsoft network server: Digitally sign communications (always): This policy controls whether the server providing SMB required signing. It determines if SMB signing will have to be negotiated prior to further communication.
2. Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Microsoft network server: Digitally sign communications (if client agrees): This policy determines if SMB server will negotiate SMB signing with clients that request it.

Active Windows

SMBv1 is enabled (Le protocole)

- **La Cause** : Le serveur accepte encore la **version 1** du protocole SMB (un vieux langage de communication).
- **La Conséquence** : C'est une faille de type "exécution de code". Un pirate peut utiliser des outils pour prendre le contrôle total du serveur à distance (comme l'a fait le virus WannaCry). C'est dangereux car le protocole lui-même est troué.

SECURITY INDICATOR
SMBv1 is enabled on Domain Controllers

ICE Found **73**

SEVERITY

Critical

WEIGHT

8

Security Frameworks
MITRE ATTACK

- Privilege Escalation
- Credential Access

Description
This indicator looks for domain controllers where SMBv1 protocol is enabled.

Likelihood of Compromise
SMBv1 is an old protocol, considered unsafe and susceptible to all kinds of attacks. It was publicly deprecated by Microsoft in 2014.

References
[Configure SMB Signing with Confidence](#)

Result
Found 1 DCs with SMBv1 Enabled.

DistinguishedName	HostName	State	Ignored
CN=SERV_UCL,OU=Domain Controllers,DC=stage,DC=local	serv-ucstage.local	SMBv1 is enabled	False

Showing 1 of 1

Remediation Steps
Microsoft recommends to disable SMBv1 whenever possible on both client and server side. Do note, before disabling SMBv1 and to avoid additional errors, make sure best practices are followed regarding the usage of deprecated OS (Windows 2003, 2008, XP, CE), network printers using SMB1 scan2shares functionalities, or software accessing Windows share with a custom implementation relying on SMBv1.

Users with SPN defined

Cet indicateur permet de réaliser un inventaire visuel de tous les comptes utilisateurs qui possèdent des SPN.

- **Explication (Cause)** : En règle générale, les SPN ne sont définis que pour des services dits "Kerberisés". L'outil a détecté que le compte dns-serv-ucs possède un SPN associé : DNS/serv-ucs.stage.local.
- **Conséquence (Risque)** : Bien que cela puisse être une configuration normale pour un service, la présence de SPN sur des comptes utilisateurs classiques est une source de préoccupation. Ces comptes deviennent des cibles privilégiées pour des attaques de type **Kerberoasting**. Dans cette attaque, un pirate peut demander un ticket de service pour ce compte et tenter de casser le mot de passe hors ligne (offline), ce qui peut mener à une compromission de compte si le mot de passe n'est pas suffisamment robuste.

SECURITY INDICATOR

Users with SPN defined

IDE Found 96

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATTACK

• Privilege Escalation

MITRE DEFEND

• Detect - Domain Account Monitoring

Description

This indicator provides a way to visually inventory all users accounts that have SPNs defined. Generally SPNs are only defined for "Kerberized" services, so if you see an account with an SPN that should not have one, this could be cause for concern.

Likelihood of Compromise

SPNs are generally only defined for service accounts or other services that use Kerberos. If you see SPNs on other accounts, they are worth investigating to determine if they are just an administrative error.

References

[Audit User Account Management](#)

Result

Found 1 users with associated SPN.

DistinguishedName	SamAccountName	ServicePrincipalName	AESEnabled	Ignored
CH\dns-serv-ucs\CH\Users,DC=stage,DC=local	dns-serv-ucs	DNS/serv-ucs.stage.local	False	False

Showing 1 of 1

Remediation Steps

If possible use Group Managed Service Accounts instead of regular users or ensure that all users that have an SPN are not primary users and considered as service accounts.

Primary users with SPN not supporting AES encryption on Kerberos

Cet indicateur affiche tous les utilisateurs disposant d'un nom de service principal (SPN) qui ne supportent pas les types de chiffrement **AES-128** ou **AES-256**.

- **Explication (Cause)** : Le compte identifié utilise des algorithmes de chiffrement obsolètes et plus faibles, comme **RC4**, pour sécuriser ses tickets Kerberos au lieu du standard moderne AES. Cela se produit souvent par défaut sur d'anciennes configurations de comptes de service.
- **Conséquence (Risque)** : Le chiffrement AES est beaucoup plus robuste que le RC4 contre les tentatives de cassage de mot de passe. L'utilisation de chiffrements faibles rend ces comptes extrêmement vulnérables aux attaques de type **Kerberoasting**. Un attaquant peut forcer une dégradation du chiffrement (*downgrade attack*) vers RC4 pour faciliter le cassage hors ligne du mot de passe du compte de service, ce qui peut mener à une compromission rapide de ses identifiants.

1

SECURITY INDICATOR

Primary users with SPN not supporting AES encryption on Kerberos

IDE Found

91%

SEVERITY

Medium

WEIGHT

5

Security Frameworks

MITRE ATTACK

- Privilege Escalation
- Credential Access

ANSSI

- valid3_kerberos_properties_encryption

Description

This indicator shows all Primary users with SPNs that do not support AES 128 or AES 256 encryption type.

Likelihood of Compromise

AES encryption is stronger than RC4 encryption. Configuring primary users with SPN to support AES encryption will not mitigate attacks such as Kerberoasting but does force AES by default, meaning that it is possible to monitor for encryption downgrade attacks to RC4 (Kerberoasting attacks).

References

[Network Security: Configure encryption types allowed for Kerberos \(Microsoft Learn\)](#)
[Service accounts supported encryption algorithms \(ANSSI\)](#)
[Kerberos \(spnauthentication.disabled\) \(ANSSI\)](#)

Result

Found 1 Primary users with SPN not supporting AES encryption

DistinguishedName	SamAccountName	ServicePrincipalName	Ignored
CN=dns serv ucs,CN=Users,DC=stage,DC=local	dns serv ucs	DNS/serv ucs.stage.local	False

Showing 1 of 1

Remediation Steps

Best practice is to enable AES encryption support on service accounts.

ActiveX Windows

Write access to RBCD on DC

Cet indicateur recherche les utilisateurs ne faisant pas partie des groupes d'administration restreints (Domain Admins, Enterprise Admins) qui possèdent des droits d'écriture sur l'attribut msds-AllowedToActOnBehalfOfOtherIdentity des contrôleurs de domaine.

- **Explication (Cause)** : L'audit a détecté qu'un ou plusieurs comptes disposent de permissions étendues permettant de configurer la délégation RBCD sur le serveur critique serv-ucs. Ces droits sont souvent accordés par erreur lors de la délégation de tâches administratives.
- **Conséquence (Risque)** : Il s'agit d'une vulnérabilité majeure car elle permet à un attaquant de forcer le contrôleur de domaine à **usurper l'identité de n'importe quel utilisateur**. En exploitant ce droit d'écriture, un pirate peut configurer une délégation pour s'octroyer les privilèges d'un administrateur du domaine et prendre ainsi le contrôle total de l'annuaire stage.local.

1

SECURITY INDICATOR

Write access to RBCD on DC

IDE Found

88%

SEVERITY

High

WEIGHT

6

Security Frameworks

MITRE ATTACK

- Credential Access

Description

This indicator looks for Write access on RBCD for Domain Controllers to users who are not in Domain Admins, Enterprise Admins and Built-in Admins groups.

Likelihood of Compromise

This setting enables configuring RBCD on Domain Controllers. An attacker that is able to gain Write access to RBCD for a resource can cause that resource to impersonate any user (except where delegation is explicitly disallowed). Write on RBCD is always a high privilege, but when it is on a DC, the impact is substantial as an attacker can delegate to a controlled resource as a privileged user and abuse the DC services.

Result

Found 1 DCs on which the listed principals can write to their msds-AllowedToActOnBehalfOfOtherIdentity attribute.

Access	DistinguishedName	Ignored
S-1-5-32-548 Allow GenericAll on: All Properties	CN=SERV_UCLDCL=Domain Controllers,DC=stage,DC=local	False

Showing 1 of 1

Remediation Steps

For each DC listed, ensure that the principals who can set resource-based constrained delegation are valid.

Write access to RBCD on krbtgt account

Cet indicateur recherche les utilisateurs (en dehors des groupes d'administration restreints) qui possèdent des droits d'écriture sur l'attribut msds-AllowedToActOnBehalfOfOtherIdentity

du compte **krbtgt**. Le compte **krbtgt** est le compte le plus sensible de l'Active Directory, car il sert à signer tous les tickets d'authentification Kerberos du domaine.

- **Explication (Cause)** : L'audit a détecté que des permissions excessives (de type GenericAll) ont été accordées sur l'objet CN=krbtgt,CN=Users,DC=stage,DC=local. Cela signifie qu'un SID (identifiant de sécurité) non-administrateur dispose d'un contrôle total sur les propriétés de ce compte.
- **Conséquence (Risque)** : C'est une vulnérabilité majeure qui peut mener à une **compromission totale et persistante** de la forêt. Un attaquant exploitant ce droit d'écriture peut configurer une délégation RBCD pour forcer le compte **krbtgt** à usurper l'identité de n'importe quel utilisateur. Cela lui permet de générer des tickets Kerberos frauduleux (comme un *Golden Ticket*) et de devenir administrateur du domaine à volonté, même si les mots de passe sont changés.

1

SECURITY INDICATOR

Write access to RBCD on krbtgt account

IDE Found

64

SEVERITY

High

WEIGHT

7

Security Frameworks

MITRE ATT&CK

- Credential Access

Description

This indicator looks for Write access on RBCD for the krbtgt account to users who are not in Domain Admins, Enterprise Admins and Built-in Admins groups.

Likelihood of Compromise

This setting enables configuring RBCD on the krbtgt account. An attacker that is able to gain Write access to a resource can cause that resource to impersonate any user (except where delegation is explicitly disallowed). Write on RBCD is always a high privilege, but when it is on the krbtgt account, the impact is substantial because it allows the attacker to create TGTs for krbtgt for any user, which can then be used as a TGT.

Result

Found 2 principals that can write to modify AllowedToActOnBehalfOfOtherIdentity on krbtgt.

Access	Identity	DistinguishedName	Ignored
Allow: GenericAll on: All Properties	S-1-5-32-548	CN=krbtgt,CN=Users,DC=stage,DC=local	False
Allow: ReadProperty, WriteProperty on: modify AllowedToActOnBehalfOfOtherIdentity	AUTORITE NT\SELF	CN=krbtgt,CN=Users,DC=stage,DC=local	False

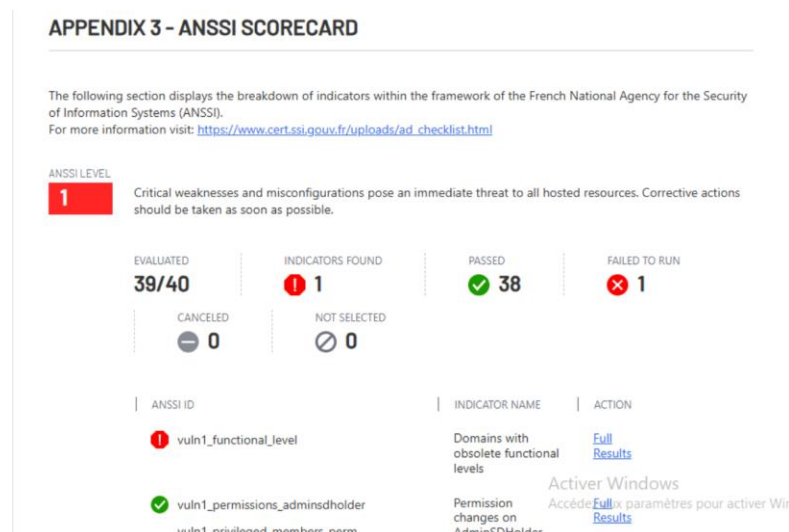
Showing 2 of 2

Remediation Steps

Review the list and ensure that there are no unnecessary principals who can set resource-based constrained delegation on krbtgt.

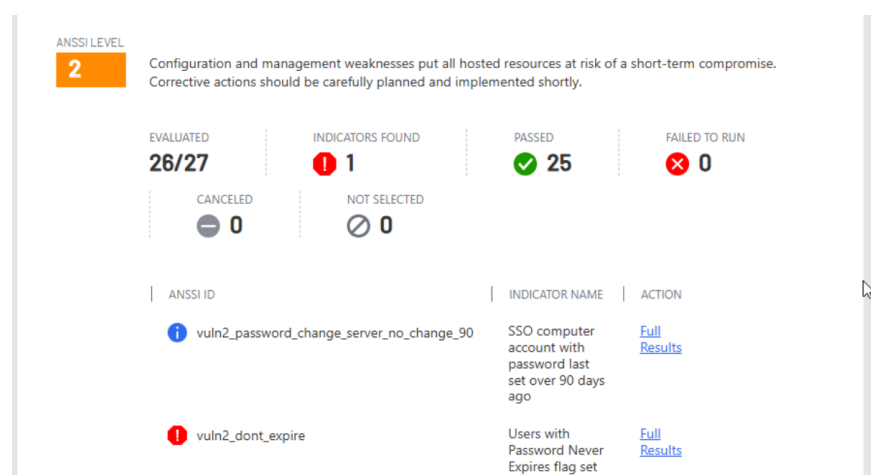
Niveau de risque ANSSI : Level 1 (Critique)

Le rapport indique un **ANSSI LEVEL 1** marqué en rouge. Cela signifie que des faiblesses critiques et des erreurs de configuration posent une **menace immédiate** à toutes vos ressources hébergées. Des mesures correctives doivent être prises dès que possible.



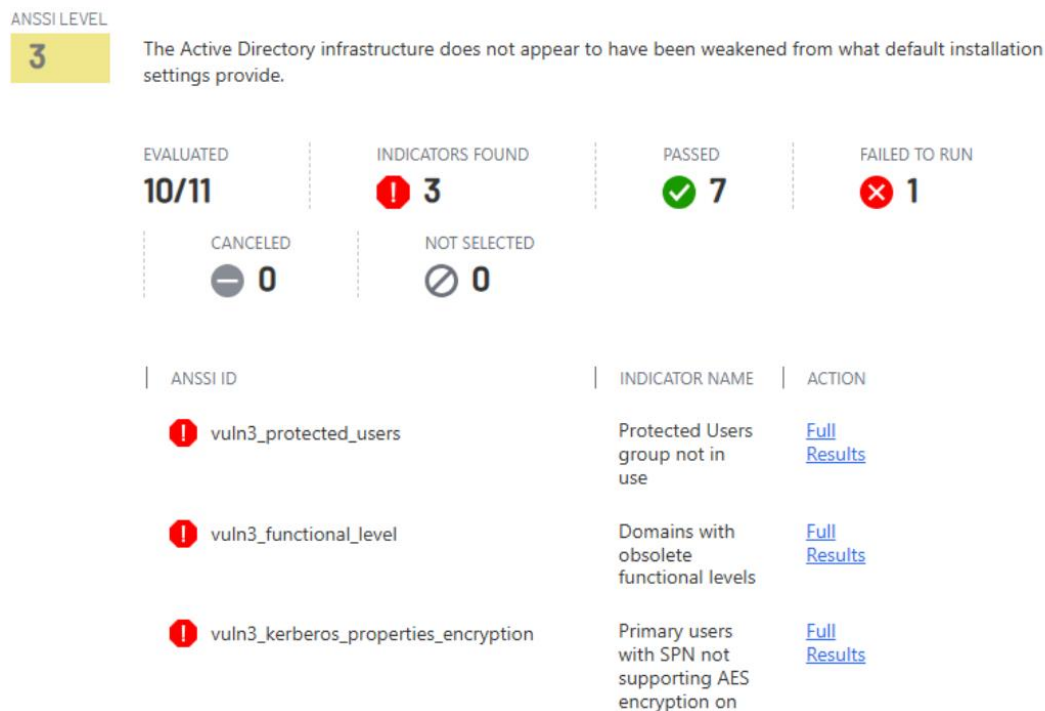
Niveau de risque ANSSI : Level 2 (Orange)

Le rapport affiche un **ANSSI LEVEL 2**. L'agence préconise que des actions correctives soient soigneusement planifiées et mises en œuvre rapidement pour éviter une exploitation par un attaquant.



Niveau de risque ANSSI : Level 3 (Jaune)

Le rapport indique un **ANSSI LEVEL 3**. À ce stade, l'infrastructure ne semble pas avoir été dégradée par rapport aux réglages d'usine, mais elle manque de mesures de durcissement avancées.



Niveau de risque ANSSI : Level 4 (Bleu)

Le rapport affiche un **ANSSI LEVEL 4**. Bien que la couleur bleue suggère un environnement globalement bien géré, le rapport identifie des points de friction persistants qui empêchent d'atteindre une sécurité optimale.

